EWB Courses - AI-Powered Cybersecurity

Assessment 01: Security Foundations

Name	Ranveer Singh
Batch / Group	Batch 1
Assessment issued	18 October 2026

Task A: Secure a student account

A1 and A2: Risks and controls

Risk	Asset	CIA impact	Control	Limitation
1. Same short password for email and learning portal	Email and portal accounts	C: someone who guesses it can read her mail and portal. I: they can change her work.	A different long passphrase for each account, saved in a password manager.	If the master password of the manager is weak or stolen, everything is exposed.
2. Approving sign-in prompts she did not start	Her login and MFA	C and I: an attacker who has the password gets in as soon as she taps approve.	Approve only logins she started. Deny the rest and change the password.	It depends on her paying attention. A tired person may still tap by mistake.
3. Delaying device updates	Laptop and its files	C, I and A: malware can steal, change or lock her files.	Turn on automatic updates.	It does not stop phishing or bugs nobody knows about yet.
4. Only one copy of the project	Project files	A: if the laptop is lost, broken or hit by ransomware, the work is gone.	Keep a second copy in cloud storage and one on a USB drive.	Backups can also be stolen or infected, and syncing may copy a bad file.
5. Friend uses the laptop while Mira is signed in	Her accounts and files	C: friend can see private data. I: anything the friend does is blamed on Mira.	Lock the screen when she leaves. Give the friend a guest account.	It does not help if Mira shares her password.

My top three actions

First, unique passwords. Email is the key to her other accounts because resets go there. With one reused password, one leak opens everything, so this is the biggest risk.

Second, approve only prompts she started. MFA is her last barrier, and changing this habit costs nothing.

Third, lock the laptop and use a guest account. It is quick, free and stops direct access. Updates and backups come after, because they protect against slower problems.

A3: Authentication and authorisation

Authentication is proving who you are. On the learning portal, Mira does this with her password and the MFA approval. Authorisation is what the portal lets her do after that. She can open her own courses, submit work and see her own marks, but she cannot change other students' marks or open teacher pages.

Task B: Analyse a suspicious message

B1: Five warning signs

Phrase from the message	Why it needs checking
"FINAL WARNING"	It creates panic with a 20 minute limit, so people act before they think or ask anyone.
campus-awards.example	My college normally uses campus.example. This is a look-alike domain, and the link goes to the same domain.
help@personal-awards.example	This is the Reply-To address. It is different from the sender and is not the college domain, so my reply would go to someone else.
"enter your college password and OTP"	A college should not ask for a password and OTP on a link. The OTP is secret, and with both someone can log in as me.
"Do not contact the college office"	It tries to stop me from checking. A real office would not tell students to avoid it.

Extra: it also asks for a photo of my identity card, which could be used for identity theft.

B2: Safe verification

1. Do not click the link, reply, or call any number in the message.

2. Open the college website by typing the address or using my own bookmark, and look for a scholarship notice there.

3. Take the office phone number or email from the official site or my admission papers, and ask them if I was approved.

4. Log in to the official student portal from my bookmark and see if any scholarship status is shown.

5. Forward the message to the college IT helpdesk using their official email.

HTTPS only means the connection is encrypted. Anyone can get HTTPS for a fake domain, so it does not prove the message is real. A display name like "Scholarship Desk" can be typed by anyone, so it also proves nothing.

B3: Plan if the student already entered the password and OTP

1. **Containment:** The student should change the college password right away from the official website, not from the message link, on a device they trust. The new password must not be used anywhere else.

2. The student should sign out of all other sessions, reset MFA if possible, and change the password on any other site that used the same one.

3. **Reporting:** The student tells the college IT helpdesk through the official contact and shares the message, but never the password or OTP. If an ID card photo was sent, the college should be told. In India it can also be reported at cybercrime.gov.in or helpline 1930.

4. **Follow-up:** The student checks recent sign-in activity, the recovery email and phone, and mail forwarding rules for anything unknown. They should not reply to the sender and should watch for more suspicious messages over the next few weeks.

B4: One thing I cannot know from this message alone

I cannot tell whether the scholarship is real, because I only have the text of the message. It would help to have the college scholarship office confirm whether any such message was sent, and the full email headers so IT can check where it really came from.

Task C: Triage a sign-in alert

C1: Timeline

Time	Observed (logs and student statement)	My interpretation
09:00-09:01	Log: student07 logged in and MFA was approved from 192.0.2.10, the usual classroom IP. Statement: the student did not sign in after 09:05.	Looks like a normal login by the student.
10:14-10:16	Log: from a new IP, 198.51.100.23, two failed passwords and then a success.	Could be guessing, or someone who knew the password and mistyped. Not proven.
10:17-10:18	Log: MFA denied at 10:17, approved at 10:18. Statement: the student approved a prompt around 10:18 to stop repeated requests. The log does not say who denied the first one.	Looks like prompt fatigue: repeated prompts until someone approved just to stop them.
10:20	Log: session created from 198.51.100.23. Statement: the student says they did not sign in.	The student probably did not start this session, so the account may be compromised. The IP does not tell who the person is.

C2: Explanations and extra checks

Likely explanation: Someone else knew or guessed the password, logged in from the new IP and kept sending MFA prompts. The student approved one by mistake and the attacker got a session.

Alternative: It was the student's own login, or another of their devices, on a different network such as mobile data or a VPN, and the student is mistaken about it. A different IP alone is not proof of an attacker.

Two checks:

1. Look at the device details of the 10:20 session (browser, device ID, network type) and compare them with the student's usual device.

2. Check what the account did after 10:20 (password change, new MFA device, mail forwarding, downloads) and whether the same IP tried other accounts.

C3: Three response actions for the IT team

1. **Protect the account:** The attacker's session may still be active, so first revoke all sessions and tokens, reset the password and re-register MFA on a trusted device.

2. **Preserve evidence:** Right away, also export the sign-in, MFA and session logs with timestamps and keep a protected copy. Do not edit or delete anything.

3. **Check the damage:** Review what the session accessed and whether the same IP touched other accounts. Tell the student not to approve prompts they did not start.

C4: Incident summary

On 18 October 2026, student07 logged in normally at 09:00 from the usual classroom IP. At 10:14 to 10:20, a new IP, 198.51.100.23, had two failed passwords, then a success, one MFA denial, one MFA approval and a session. The student says they did not sign in and approved a prompt to stop the requests. This may be unauthorised access after prompt fatigue, but we cannot identify a person from the IP. Priority is high. Next action: preserve logs, revoke sessions, reset password and MFA, then check account activity.

Task D: Review an AI security answer

D1: Five unsafe or unsupported claims, corrected

Claim in the AI output	Correction, with evidence or reference
"The email is safe because it uses HTTPS."	HTTPS only encrypts the connection, and fake sites can use it too. The Task B message also had a look-alike domain, a different Reply-To and a request for an OTP. CISA's phishing guidance lists such signs.
"The sign-in logs prove that the person using 198.51.100.23 stole the password."	Logs show events from an IP address, not who the person is, and not how the password was obtained (Task C log). 'Suspected unauthorised access' is the right wording.
"MFA prevents every account compromise."	MFA helps a lot but not always. In Task C the student approved a prompt by mistake. CISA also recommends MFA as one layer, not a complete fix.
"Delete the suspicious logs."	Logs are the evidence of what happened, so they should be saved and protected. Deleting them would also make the investigation in Task C impossible.
"Send the student's password to support so they can test it."	Passwords should never be shared, even with support (CISA password guidance). The student should change it, and IT can check the account without the password.

The AI also sounded very sure about everything. NIST AI 600-1 warns about confabulation, where AI states wrong things confidently, so its answers must be checked against evidence.

D2: A better prompt

"This is a training exercise. The data below is fictional and synthetic, with no real people. Analyse only the evidence I give you and do not add outside facts. 1) List the facts that are directly in the evidence. 2) List your assumptions separately and label them as assumptions. 3) Give the most likely explanation and at least one alternative. 4) Say what you are unsure about and what extra evidence would help. 5) Do not ask me for any password, OTP, ID photo or other secret, and do not suggest deleting logs. If something is not in the evidence, write 'not known'. [paste synthetic evidence here]"

D3: My corrected security advice

Do not trust a message only because it uses HTTPS. HTTPS only protects the connection; it does not prove the sender is honest. If a message asks for a password, OTP or ID photo, stop and check with the college through an official website or phone number you found yourself. MFA helps a lot, but it is not perfect, so only approve prompts you started. If prompts keep coming, deny them and change your password. Logs show events from an IP address, not the exact person, so IT should say 'suspected' until more evidence is found. Never delete logs; save copies and limit who can change them. Never send your password to anyone, including support. If you already entered it, change it from the official site, sign out other sessions, and report it to IT.

D4: AI-use declaration and references

AI-use declaration: I used an AI tool (Claude) to help draft and organise my answers. I read the answers, checked them against the assessment evidence and the references below, and changed the wording where needed. I did not use any real student data, passwords or OTPs.

Evidence / reference notes:

1. CISA - Secure Our World (https://www.cisa.gov/secure-our-world): used for basic guidance on strong unique passwords, MFA and spotting phishing messages (urgency, odd links, asking for private information). Supports Tasks A, B and D1.

2. NIST - Generative AI Profile, AI 600-1 (https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf): used for the point that AI can confabulate and its answers must be verified. Supports D1 and D2.